

Sovereign V1: Multi-Framework AI Compliance Platform - Product Requirements Document (PRD)

Problem

Enterprises are deploying AI into regulated workflows faster than compliance teams can interpret, audit, and document requirements—leading to costly delays, inconsistent decisions, and material risk exposure. Sovereign V1 delivers production-grade, multi-framework AI compliance assessments that are accurate, fast, and defensible, reducing false positives/negatives and keeping pace with evolving regulations.

Evidence: Compliance reviews average 2–6 weeks per AI use case with 25–40% rework. Regulatory changes arrive monthly, and manual processes cannot scale across EU AI Act, SOX, and GDPR—today's core frameworks in Sovereign V1.

High Level Approach

Sovereign V1 uses 9 specialized LLM judges (3 per framework: GDPR, SOX, EU AI Act), multi-model routing (Haiku for stable, Sonnet for evolving/ambiguous determinations), and an Advanced RAG V1 stack for grounded evidence. A self-improvement agent continuously tunes prompts and policies via error logging, pattern analysis, and A/B testing, while a parallel execution engine and real-time observability provide fast, auditable decisions at enterprise scale.

Narrative

- **Story 1:** A global bank must certify an LLM-powered customer assistant against the EU AI Act, SOX, and GDPR. Legal, risk, and engineering teams no longer juggle spreadsheets and PDFs. With Sovereign V1, they upload artifacts, select frameworks, and receive a consolidated dashboard and executive report within minutes—complete with obligation breakdowns, evidence links, and remediation guidance.
- **Story 2:** A SaaS provider is rolling out an AI-powered analytics tool and needs SOX controls documented for auditors, along with a GDPR DPIA. Sovereign V1 maps each output to corresponding frameworks, flags gaps, and assembles evidence for a regulator-ready appendix.
- **Story 3 (Edge):** An EU company launching a multilingual AI feature uses Sovereign V1 to quickly navigate GDPR profiling risks and EU AI Act transparency obligations. When regulations update, the system reruns affected checks and provides version-aware diffs, maintaining continuous compliance.

Goals

1. **Accuracy and trust:** Deliver verifiably correct, explainable compliance decisions users can defend to auditors.
2. **Speed at scale:** Reduce review cycle time by 70–90% through parallelization and automation.
3. **Cost efficiency:** Cut per-assessment cost by 50–70% vs. manual baselines while improving quality.
4. **Coverage and currency:** Maintain up-to-date mapping across prioritized frameworks with SLA-backed updates.
5. **Enterprise readiness:** Provide data security, RBAC, audit trails, and integrations expected by regulated buyers.

6. **Delightful UX:** Make reports and workflows business-friendly, with clear remediation and version comparisons.

Metrics

Metric	Target/Actual
Verified Compliance Decision Accuracy	≥94% (95% CI ±2%)
True Positive Rate (TPR)	95.8%
True Negative Rate (TNR)	≥90%
p95 Assessment Latency (multi-framework)	<20 seconds
Cost per Assessment	\$0.07–\$0.35 per scan
Framework Update SLA	72 hours (24 for critical updates)
UX/NPS	NPS ≥60; task success ≥90%; insight <3 minutes
Guardrails	FP rate +>3 pts MoM triggers rollback; 0 data leakage; 99.9% uptime

Validation, Quality, & Continuous Improvement

- **Golden dataset:** 200 labeled scenarios spanning EU AI Act, SOX, and GDPR; quarterly expansion planned.
- **Methodology:** Stratified train/val/test splits; 5-fold cross-validation.
- **Testing:** Nightly regression, judge-level canaries, version pinning, and diff reporting.
- **A/B testing:** Multi-armed bandits for prompt variants and routing; typical test duration 1–2 weeks.
- **Change management:** Signed model/prompt versions, audit logs, SRG (Standards Review Group) sign-off.
- **Regulatory tracking:** Semantic watchlist over regulator feeds; triaged updates with dashboard visibility.

Impact Sizing Model

Assumptions:

- Average enterprise AI portfolio: 40 use cases/year; 3 assessments/use case annually (initial + quarterly).
- Manual baseline: \$8,000 cost and 4 weeks per assessment; 25% rework due to inconsistency (\$2,000 additional).
- Sovereign V1: \$0.07–\$0.35 per scan; residual human review 6 hours at \$150/hr (\$900).
- Adoption: Year 1—20 customers; Year 2—60 customers. Each runs 120 assessments/year.

Sample Calculation (per enterprise/year):

Model	Cost	Total
Manual	\$8,500 × 120	\$1,020,000

Sovereign V1 (all-in)	Up to $\$900 \times 120 + \42 (scan)	\$108,042
Savings	-	\$911,958
Time reduction	4 weeks → <1 day	70-90%

Vendor revenue model (illustrative):

Line Item	Amount
Platform ARR	\$150,000
Usage	$\$0.35 \times 120 = \42
Total ARR/Enterprise	~\$150,042

Non-goals

- Replace legal counsel or regulators: Provides decision support with defensible evidence, not legal determinations.
- Extend beyond three frameworks in V1: Expansion is architected but not in current scope.
- Automated code changes to remediate findings: Guidance and ticket integration only.
- Automated adversarial red-teaming: Future roadmap item.

Solution Alignment

Perimeter

- **Frameworks:** EU AI Act, SOX (AI-adjacent controls), GDPR DPIA/Profiling (frameworks architected for expansion).
- **Artifacts:** Model cards, prompts, datasets (samples/metadata), logs, DPIAs, SOPs.
- **Outputs:** Executive summary, obligation checklist, evidence, risk heatmap, remediation plan, audit trail, version compare.

Differentiators

- 9 specialized judges (3 for each current framework; scalable to more).
- Multi-model routing (Haiku for stable checks; Sonnet for evolving/ambiguous), fallback strategies.
- Advanced RAG V1: Adaptive query classification, hybrid search (sparse + dense + RRF), source pinning for evidence.
- Self-improvement agent: Feedback, automated prompt improvement, online A/B testing.
- Parallel execution engine; p95 latency <20s; full cost/latency/usage telemetry.
- Enterprise controls: RBAC, encryption, audit logging, API/SDK, and integrations.

Target Customers

- Regulated enterprises (finance, tech, insurance, healthcare).
- AI-driven companies needing rapid, defensible compliance.

Key Features: Plan of Record

7. **Framework Orchestrator and Selector**
 - Multi-framework selection (EU AI Act, SOX, GDPR), obligation mapping, and impact scope estimator.
8. **9 Specialized Judges with Consensus Engine**
 - 3 per framework; per-framework judgment, confidence scores, abstain/fallback rules.
9. **Multi-Model Routing**
 - Haiku for structured checks; Sonnet 4.5 for ambiguous/evolving scenarios; policy-based routing.
10. **Advanced RAG V1**
 - Adaptive query classification, hybrid BM25 + semantic search, RRF fusion, context packing, source pinning and citation integrity.
11. **Parallel Execution Engine**
 - ThreadPoolExecutor for judge parallelization, concurrency, and timeout strategy.
12. **Real-Time Observability Dashboard**
 - Latency/cost/usage metrics; judge- and framework-level insights.
13. **Executive Reporting & Evidence Binder**
 - One-click PDF/HTML report; appendix with citations; export in JSON/CSV; evidence binder.
14. **Violation and Incident Manager**
 - Scoring, mapping, remediation, and ticket integration.
15. **Version Comparison**
 - Diffs across frameworks, obligations, and artifacts.
16. **Feedback & Self-Improvement**
 - Inline/user feedback, A/B experimentation, auto-prompt refinement.
17. **Security & Governance**
 - RBAC, encryption, retention, audit trail.
18. **API/SDK & Integrations**
 - REST/WS APIs, webhooks, and connectors for Jira, ServiceNow, Slack, SIEM, CSV exports.

Technical Specifications

- **Frontend:** Next.js (React, TypeScript); deployed on Netlify; accessibility conformant.
- **Backend:** Python 3.11, FastAPI, ThreadPoolExecutor for parallel judge execution; deployed on Render.
- **Vector DB:** Pinecone (~720 regulatory docs indexed).
- **Embeddings:** OpenAI text-embedding-3-small.
- **Observability:** OpenTelemetry, Prometheus, Grafana dashboards; cost tracking.
- **Security:** OIDC SSO, RBAC, AES-256 encryption at rest/TLS in transit; region-pinned indices; audit logs.

Key Logic

- **Judge Mapping:** 3 per framework (EU AI Act, SOX, GDPR).
 - E.g., For GDPR: Lawfulness/Profiling, Data Subject Rights, DPIA Sufficiency.
- **Routing**
 - Stable, clear obligations → Haiku (faster/cheaper).

- Evolving/ambiguous or diffuse evidence → Sonnet 4.5.
- Fallback: repeat with alternate model or abstain on low confidence.
- **Evidence Retrieval**
 - Hybrid search (BM25 + embeddings, RRF), source pinning for traceable citations.
- **Consensus**
 - Weighted majority across judges; escalate to alternate model if unresolved conflict.
- **Parallelism**
 - Sharded execution with concurrency; timeouts, exponential backoff; content-addressed caching.
- **Self-Improvement**
 - Logs errors, analyzes patterns, surfaces candidates for reroute/prompt change, runs A/B test.

Deployment

Component	Deployment
Frontend	Netlify
Backend	Render
Vector DB	Pinecone (~720 regulatory docs)
Embeddings	OpenAI text-embedding-3-small

Roadmap & Future Considerations

- **Expansion to new frameworks** (HIPAA, PCI, COPPA, etc.): Architected and extensible, but not included in V1 launch.
- **Enhanced red-teaming/orchestration, on-prem, further model routing strategies, deeper automation, multilingual support:** On roadmap.
- **Framework versioning/roll-forward/rollback, SRG-controlled prompt management:** Fully supported for V1 and extensible.

Launch Plan

- **Alpha (first 4-6 accounts):** Validate core engine, judge accuracy, and parallelization on real artifacts. Exit: VCDA $\geq 90\%$, p95 latency <30s, 0 critical security issues, 2 case studies.
- **Private Beta:** Harden RAG V1, observability, and executive reporting. A/B testing on prompts/routing, feedback cycles.
- **GA:** Enterprise controls, reporting polish, real-time monitoring and incident management. Exit: NPS ≥ 60 ; 3 enterprise references; 99.9% uptime; SOC 2 readiness.

Milestones

Phase	Milestone	Status
Core Engine	9-judge mapping and consensus engine	Complete
Advanced RAG V1	Hybrid search, source pinning, retriever	In progress

	optimizations	
Self-Improvement	Error log pipeline, feedback surfacing, prompt tuning	In progress
Observability	Real-time dashboard, cost tracking, alerts	Complete
Business/UX	Reporting, version compare, integrations	In progress

Regulatory Change Control & Version Management

Sovereign V1 operationalizes regulatory alignment with deterministic versioning, real-time monitoring, and impact-aware rollbacks/roll-forwards.

Regulatory Monitoring and Change Notifications

- **Coverage:** EU AI Act, SOX, GDPR.
- **Watch Service:** Semantic crawlers over regulator feeds and trusted publishers; NLP-based delta detection.
- **Notifications:** In-app/banner, email, Slack; “Impacted Assets” listing; ServiceNow auto-open for critical updates.

Corpus and Mapping Versioning

- All core artifacts, mappings, and judge prompts are versioned (SemVer).
- Compatibility matrix enforces safe deployment combinations.

Assessment Traceability & Impact Analysis

- Immutable run manifest captures framework, mapping, prompt/model versions.
- Every finding is linked to its citation and context.
- Impact analyzer: One-click list of assessments impacted by a version change, batch rerun/planning.

Integration Extensibility & API-First Design

- **Plugin Architecture:** Designed for extension—with parsers and extractors for new artifact types.
- **APIs & Webhooks:** REST and WebSocket endpoints for running assessments, retrieving findings, and event hooks (started/completed, finding.created, etc.).
- **DevOps/ITSM Connectors:** Integrations for GitHub, GitLab, Jira, ServiceNow, Slack, SIEM, GRC.
- **Custom Regulatory Mapping:** GUI and API for mapping obligations to internal controls/evidence repositories.

Complete Audit Chain & Defensibility Artifacts

- **Evidence Binder:** One-click export with executive summary, obligation-level findings, and citations.
- **Tamper-Evident Logging:** Immutable, hash-chained logs of all actions, config changes, and versioning.
- **Reproducibility:** sovereign-replay and sovereign-diff tooling for deterministic reruns and change diffs.
- **Legal Hold:** Run-level and workspace-level holds with suspension of deletion policies; regulator-mandated alignment.

Granular RBAC & Data Lifecycle Management

- **Role Hierarchy:** Org Admin, Project Owner, Compliance Lead, Reviewer, Contributor, Viewer, Auditor, Service Account.
- **Scope and Governance:** Fine-grained permissions, SCIM integration, access reviews.
- **Privacy & Retention:** Configurable retention, GDPR/CCPA ready, built-in data minimization/masking, region-pinned storage, cryptographic erasure.

Regulatory Test Scenario Library & “What-If” Simulation

- **Scenario Library:** 200 labeled gold cases covering EU AI Act, SOX, GDPR (expandable, architected for more in future).
- **Simulation:** Run “what-if” and delta impact analyses across framework/judge/prompt versions and artifacts.
- **Continuous Stress Testing:** Benchmarks, maturity tracking, and anomaly detection on nightly/weekly stress runs.

Human-in-the-Loop Escalation & Governance

- **Escalation Triggers:** Low-confidence, high-severity, conflicting findings, major version changes.
- **Expert Review:** Dual review and audit; structured rationale templates.
- **Governance Controls:** Quarterly SRG sign-off for material changes, exception registers, policy publishing.

Enterprise Onboarding & Workspace Management

- **Onboarding Flows:** SSO/SCIM setup, project/workspace creation, artifact ingestion, and quick-start templates.
- **Workspace Hierarchy:** Organization → Workspace → Project → Assessment → Run.
- **Collaboration:** Comments, notifications, checklist tasks, custom branding.
- **Admin/Health Tools:** Role management, retention configuration, real-time deployment health status.

Transparent Pricing & Capacity Planning

Pricing Metric	Sovereign V1
Cost per scan (assessment)	\$0.07-\$0.35
Usage Overage	\$150 per 1,000 assessments
High-Volume Discounts	Available
Add-Ons	Custom connectors, analytics
Concurrency/Slot limits	Growth:10; Ent:40; Reg+:100
Audit Chain	Always included

- **Margin Forecasts:** Target margins 65-75%+ with scale.
- **Pricing Protections:** 12-24 month rate locks; MSA-based procurement; audit reports available.

Note: Sovereign V1 is engineered for rapid expansion to additional frameworks, gold datasets, and deeper automation, but scope above reflects current, productionized system. All features are designed for extensibility and scale in subsequent releases.